Oluwafemi Noah Taiwo

Application Security Engineer & Penetration Tester

Lagos, Nigeria | github.com/Vharse | linkedin.com/in/[your-profile]

PROFESSIONAL SUMMARY

I am an Application Security Engineer and Penetration Tester with hands on experience in web application exploitation (OWASP Top 10), Zero Trust API defense, and DevSecOps pipeline automation. Skilled in setting up CI/CD security gates, containerized reverse proxies with JWT/mTLS authentication, and SIEM logging systems. Experienced in manual vulnerability assessments, analyzing attack vectors, and working with developers to fix security issues in code.

CORE COMPETENCIES

• Offensive Security & Pentesting: Web App Penetration Testing, OWASP Top 10 (SQLi, XSS, Command Injection, BOLA), Reconnaissance & Footprinting, Network Scanning (Nmap, Netdiscover), OWASP ZAP, Fuzzing, Manual Exploitation.

• **API & Application Defense:** Zero Trust Architecture, OAuth 2.1, Asymmetric Cryptography (RSA / PyJWT), RBAC & ABAC Access Controls, PostgreSQL Row-Level Security (RLS), Redis Rate-Limiting & Progressive IP Bans, Async Reverse Proxies (HTTPX / Nginx), Server-Side Input Sanitization.

• **DevSecOps & Pipeline Security:** GitHub Actions, CodeQL, Semgrep, SonarQube,

Gitleaks, Trivy, Software Bill of Materials (SBOM), OpenSSF Scorecard, Open Policy Agent (OPA / Rego), DefectDojo.

• **Systems, Networks & Diagnostics:** Wireshark Packet Analysis, Linux Syslog, SIEM Telemetry, Active Directory GPO Auditing, PowerShell Scripting.

SECURITY ENGINEERING & PENETESTING PROJECTS

DevSecOps, Supply Chain & Offensive Security PipelineTechnologies: GitHub Actions, CodeQL, Semgrep, SonarQube, OPA (Rego), Trivy, Gitleaks, OpenSSF Scorecard, OWASP ZAP, DefectDojo, Docker

• I built a modular CI/CD security pipeline using custom GitHub Actions to catch security flaws early in the development lifecycle.

• I applied Infrastructure-as-Code (IaC) checks using Open Policy Agent (OPA) with custom Rego policies (s3_check.rego) to stop misconfigurations before deployment.

• I also integrated automated SBOM generation and OpenSSF Scorecard audits to monitor third-party dependencies and open-source supply chain risks.

• Set up automated SAST checks (CodeQL, Semgrep, SonarQube) and secret scanning (Gitleaks) to catch vulnerabilities and hardcoded keys before code gets merged.

• I automated DAST scans with OWASP ZAP and Trivy container checks, sending all findings to DefectDojo for tracking along with real-time Slack alerts.

Containerized Zero Trust API Gateway

Technologies: Python, FastAPI, Redis, Docker, PyJWT, Nginx, mTLS, OAuth 2.1

• Built and security-tested a Zero Trust API gateway using mutual TLS (mTLS) to verify device and service identities.

• Stopped authorization bypasses and session hijacking by setting up stateless PyJWT signature verification and OAuth 2.1 flows.

• Protected endpoints from brute-force and credential stuffing attacks using Redis-backed rate limiting and automatic IP blocking.

Custom Telemetry & Defensive SIEM Engine

Technologies: Linux Syslog, Python, Prometheus, Grafana, AI Analytics

• I created a custom backend SIEM log analysis system to capture live attack logs and study exploitation attempts.

• I wrote detection rules for SSH brute-force attempts and suspicious traffic, using AI analysis to evaluate attack patterns.

• Built Grafana dashboards fed by Prometheus exporters to monitor real-time login failures and traffic spikes.

Active Directory Hardening & Privilege Audit Lab

Technologies: Windows Server, Active Directory, PowerShell, Group Policy Objects (GPOs)

• Audited Active Directory environments to locate privilege escalation risks, inactive accounts, and weak policy setups.

• Wrote custom PowerShell scripts to automate AD audits and enforce baseline security settings across the domain using GPOs.

EDUCATION & PROFESSIONAL TRAINING

Diploma in Cybersecurity (Application & Network Security Track)

SQI College of ICT

Coursework: Web Application Exploitation, SQL/Command Injection & XSS, Network Reconnaissance & IDS Evasion (Nmap, Netdiscover), Server Hardening, Cryptography, Logging & Auditing Systems.